

第四章 数据库安全性（授权）— 练习题（深层理解版）

一、选择题（每题 4 个选项）

1. 自主存取控制 (DAC) 与强制存取控制 (MAC) 的主要区别是 ()。
A. DAC 比 MAC 更安全
B. DAC 由数据所有者决定权限, MAC 由系统根据标记强制控制
C. MAC 只用于文件系统, DAC 用于数据库
D. DAC 和 MAC 没有本质区别
2. 授予对象权限时, 允许被授权用户继续传播该权限的短语是 ()。
A. WITH ADMIN OPTION
B. WITH CHECK OPTION
C. WITH GRANT OPTION
D. CASCADE
3. 授予角色权限时, 允许被授权用户继续传播该角色的短语是 ()。
A. WITH GRANT OPTION
B. WITH ADMIN OPTION
C. WITH CHECK OPTION
D. RESTRICT
4. REVOKE 中使用 CASCADE 表示 ()。
A. 只回收目标用户的权限
B. 级联回收该用户传播出去的权限
C. 如果用户传播过权限则拒绝回收
D. 回收所有用户的该权限
5. REVOKE 中使用 RESTRICT 表示 ()。
A. 级联回收所有传播的权限
B. 如果该用户已将权限传播给其他用户, 则拒绝回收操作
C. 只回收部分权限
D. 回收权限但保留角色的成员资格
6. 以下关于角色的说法, 正确的是 ()。
A. 角色是用户的集合
B. 角色是权限的集合
C. 角色只能由 DBA 创建
D. 角色不能授予其他角色
7. 拥有 RESOURCE 权限的用户可以 ()。
A. 创建新用户
B. 创建模式和基本表



- C. 创建基本表和视图，但不能创建模式和新用户
D. 拥有所有数据库权限
8. 以下 SQL 语句中，语法正确的是（ ）。
- A. GRANT ALL ON Student TO U1 WITH ADMIN OPTION
B. GRANT SELECT ON Student TO U1 WITH GRANT OPTION
C. GRANT INSERT(sno, sname) ON Student TO U1
D. REVOKE SELECT ON Student FROM U1 RESTRICT
-

二、填空题

9. 数据库安全性控制手段包括用户身份鉴别、_____、视图机制、审计和_____。
10. 授予对象权限时使用_____短语允许权限传播，授予角色权限时使用_____短语允许角色传播。
11. 角色是_____的集合，使用角色可以简化_____过程。
12. 新创建的用户默认拥有_____权限，只能登录数据库，不能创建表和视图。
13. 强制存取控制（MAC）中，系统为每个数据对象设置_____，为每个用户设置_____。
-

三、简答题

14. 简述自主存取控制（DAC）与强制存取控制（MAC）的核心区别，并各举一个适用场景。
15. 解释 CASCADE 和 RESTRICT 在 REVOKE 语句中的作用和区别。为什么说 RESTRICT 不是"部分回收"？
16. 为什么 SQL 标准禁止循环授权？请用授权传播链的例子说明循环授权会导致什么问题。
-

四、应用题（写出 SQL 语句）

17. 现有关系模式 Student(Sno, Sname, Ssex, Sage, Sdept)，请写出以下授权操作的 SQL 语句：
- (1) 授予用户 U1 对 Student 表的查询权限，并允许 U1 将此权限转授给其他用户。
- (2) 授予用户 U2 对 Student 表的 Sname 和 Sage 列的修改权限。
- (3) 收回用户 U1 对 Student 表的查询权限，同时收回 U1 传播出去的该权限。
18. 某高校教务系统有三类用户：教务员、教师、学生。请使用角色机制完成以下设计：
- (1) 创建角色 Teacher_Role。
- (2) 授予 Teacher_Role 对成绩表 SC 的查询和修改权限。
- (3) 将用户 T1、T2 添加到 Teacher_Role 角色中。
-

五、授权传播链分析题

19. 考虑以下授权操作序列：
- ① A 授予 B 对表 T 的 SELECT 权限 (WITH GRANT OPTION)
② B 授予 C 对表 T 的 SELECT 权限 (WITH GRANT OPTION)
③ C 授予 D 对表 T 的 SELECT 权限
④ A 授予 E 对表 T 的 SELECT 权限 (WITH GRANT OPTION)
⑤ E 授予 D 对表 T 的 SELECT 权限

请回答：



(1) 执行完以上操作后, 哪些用户拥有对表 T 的 SELECT 权限?

(2) 如果 A 执行 REVOKE SELECT ON T FROM B CASCADE, 哪些用户会失去权限? 哪些保留? 为什么?

20. 方案 A: 直接给 U1、U2、U3 分别授予对表 T 的 SELECT、INSERT、UPDATE、DELETE 四项权限。方案 B: 创建角色 R, 将四项权限授予 R, 再将 R 授予 U1、U2、U3。当需要收回 U1 的所有权限时, 两种方案各需要几条 REVOKE 语句? 当需要新增第 5 项权限时, 各需要修改几条语句?

六、辨析题 (判断下列说法是否正确, 并说明理由)

21. "WITH GRANT OPTION 和 WITH ADMIN OPTION 的作用完全相同, 只是关键字不同。"

22. "只要给用户授予了 CONNECT 权限, 该用户就可以创建基本表。"

23. "审计可以防止非法操作的发生。"

七、纠错题

24. 以下 SQL 语句各有问题, 请指出错误并改正:

(1) GRANT ALL ON Student TO U1 WITH ADMIN OPTION;

(2) GRANT INSERT(sno, sname) ON Student TO U1;

(3) CREATE ROLE 'Teacher_Role';

八、案例分析题

25. 某军事数据库系统存储了不同密级的作战数据。系统要求:

- 士兵只能查看"公开"和"内部"级别的数据
- 军官可以查看"公开"、"内部"和"机密"级别的数据
- 任何人不能将自己的数据访问权限授予他人
- 数据访问权限由系统根据用户级别自动控制

请回答:

(1) 该系统应该采用 DAC 还是 MAC? 为什么?

(2) 如果采用 DAC 模型, 能否满足"任何人不能将自己的权限授予他人"的要求? 为什么?

(3) 简述 MAC 模型中的"向下读、向上写"原则在该场景中如何体现。

答案

选择题

1.B 2.C 3.B 4.B 5.B 6.B 7.C 8.B

填空题

9.存取控制, 数据加密 10.WITH GRANT OPTION, WITH ADMIN OPTION 11.权限, 授权 12.CONNECT 13.敏感度标记, 许可证级别

简答题 (要点)

14. DAC: 数据所有者自主决定权限, 灵活但易扩散, 适用普通企业。MAC: 系统根据安全标记强制控制, 用户不能改变, 适用军事、政府系统。



15. CASCADE: 级联回收传播的权限。RESTRICT: 有传播则拒绝回收。RESTRICT 不是"部分回收", 而是"有传播就不让收"。
16. 循环授权如 $A \rightarrow B \rightarrow C \rightarrow A$, 若 A 权限被收回, 理论上 B、C 也应消失, 但 A 又从 C 获得权限, 形成死循环。SQL 一刀切禁止。

应用题 (要点)

17. (1) GRANT SELECT ON TABLE Student TO U1 WITH GRANT OPTION;
(2) GRANT UPDATE(Sname, Sage) ON TABLE Student TO U2;
(3) REVOKE SELECT ON TABLE Student FROM U1 CASCADE;
18. (1) CREATE ROLE Teacher_Role;
(2) GRANT SELECT, UPDATE ON TABLE SC TO Teacher_Role;
(3) GRANT Teacher_Role TO T1, T2;

授权传播链分析题 (要点)

19. (1) A、B、C、D、E 都拥有权限。
(2) B 和 C 失去权限。D 通过 E 仍然拥有权限。A、E 保留。
20. 方案 A: 3 条 REVOKE / 3 条 GRANT。方案 B: 1 条 REVOKE / 1 条 GRANT。

辨析题

21. 错误。WITH GRANT OPTION 用于对象权限传播; WITH ADMIN OPTION 用于角色或系统权限传播。
22. 错误。CONNECT 只能登录, 创建表需要 RESOURCE 或 DBA 权限。
23. 错误。审计是事后审查, 不能阻止非法操作发生。

纠错题

24. (1) 对象权限应使用 WITH GRANT OPTION, 非 WITH ADMIN OPTION。
(2) INSERT 不能指定列, 只有 UPDATE 和 REFERENCES 可以。
(3) 角色名不应加引号。

案例分析题 (要点)

25. (1) MAC。系统根据安全标记自动控制访问, 且禁止用户传播权限。
(2) 不能。DAC 允许用户传播权限, 无法强制禁止。
(3) "向下读": 军官可读机密及以下级别; "向上写": 用户不能将数据写入低于其级别的对象。

